

## Security+ 2.2 · Other Social Engineering

Mestre CyberSec · Aula 2.2 — Other Social Engineering (3:29) · [Assistir Vídeo no YouTube](#) · Treino Interativo: [edusouzamarques.github.io/cybersec](https://edusouzamarques.github.io/cybersec)

**Resumo Executivo da Aula:** Engenharia social além do email: misinformation (desinformação em escala), brand impersonation (falso suporte), pretexting (cenário inventado — 'sou auditor, preciso verificar X'), dumpster diving (papel sensível na lixeira), shoulder surfing.

### 💡 Highlights que a prova CompTIA cobra

- Pretexting: cenário FALSO mas plausível que justifica o pedido
- Misinformation: desinformar em escala (rede social) pra favorecer objetivo

### 🎯 Dicas de Prova & Cenários Típicos da Banca

- 'creates a fabricated scenario to obtain information' = pretexting

## Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.2 — Other Social Engineering)

**Por que este aprofundamento é cobrado na prova?:** O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

### • Pretexto / Pretexting

Técnica de engenharia social em que o atacante cria um cenário falso, porém plausível, para convencer o alvo a fornecer informações ou executar uma ação.

⚠ **Armadilha CompTIA:** Gatilho: *'creates a fabricated scenario to obtain information'* = pretexting. Não confundir com phishing: o pretexto é a história/identidade inventada que justifica o pedido.

### • Desinformação/Informação falsa intencional

Informação falsa ou imprecisa disseminada para enganar; desinformação é criada e espalhada deliberadamente, muitas vezes em escala por redes sociais, para influenciar opiniões ou ações.

⚠ **Armadilha CompTIA:** Gatilho: *'informação falsa em escala'* ou *'influenciar objetivo'* = misinformation/disinformation. Se houver intenção deliberada de enganar, é disinformation; se for erro, misinformation.

### • Impersonação de marca

Atacante finge representar uma marca confiável, geralmente por falso suporte, sites ou mensagens, para enganar usuários e obter credenciais ou instalar malware.

⚠ **Armadilha CompTIA:** Gatilho: *'falso suporte da Microsoft/Amazon'* = brand impersonation. Distinção: usa nome/logo de marca legítima, diferente de impersonation genérica de um indivíduo.

### • Vasculhar o lixo / Garimpagem no lixo

Vasculhar lixo ou reciclagem para obter informações sensíveis, como documentos, credenciais ou hardware descartados inadequadamente.

⚠ **Armadilha CompTIA:** Gatilho: *'papel sensível na lixeira'* = dumpster diving. Contramedida: triturar documentos e destruir mídia; não é ataque técnico, é físico/social.

### • Observação por cima do ombro

Observar a tela ou a digitação de um usuário de uma posição próxima para capturar informações sensíveis, como senhas, PINs ou dados confidenciais.

⚠ **Armadilha CompTIA:** Gatilho: *'olhar por cima do ombro'* = shoulder surfing. Contramedida: filtros de privacidade, posicionamento de tela e atenção ao ambiente.

### • Impersonação

Fingir ser outra pessoa, como colega, executivo, técnico ou autoridade, para ganhar confiança e convencer o alvo a atender a um pedido.

⚠ **Armadilha CompTIA:** Gatilho: *'fingir ser alguém confiável'* = impersonation. Pretexting é a história/cenário; impersonation é a identidade falsa assumida.

### • Typosquatting / Aproveitamento de erros de digitação

Registrar um domínio semelhante a um legítimo, contando com erros comuns de digitação, para impersonar uma marca e atrair usuários a sites maliciosos.

⚠ **Armadilha CompTIA:** Gatilho: *'domínio parecido com o original'* = typosquatting. Relaciona-se a brand impersonation; verifique URL e use bloqueio de domínios maliciosos.

### • Boato / Falso alarme

Um aviso ou ameaça falsa, geralmente disseminado por email ou redes sociais, projetado para enganar usuários e fazê-los tomar ações prejudiciais ou espalhar desinformação.

⚠ **Armadilha CompTIA:** Gatilho: 'falso vírus/alerta em corrente' = hoax. Distinção: hoax é uma mentira sobre ameaça; phishing tenta roubar credenciais/dados diretamente.

## ✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

### QUESTÃO 1 · CENÁRIO DE EXAME

Uma administradora de folha de pagamento recebe uma ligação de uma pessoa que afirma ser da equipe de auditoria interna. O chamador diz que está realizando uma revisão de conformidade e precisa que a administradora confirme os quatro últimos dígitos das contas bancárias de vários funcionários. O chamador já sabe o nome do gerente de folha de pagamento e o cronograma atual de auditoria por um documento público. A administradora é pressionada a ajudar rapidamente. Qual técnica de engenharia social o chamador está usando?

- A) Pretexting
- B) Typosquatting
- C) Dumpster diving
- D) Shoulder surfing

### QUESTÃO 2 · CENÁRIO DE EXAME

Funcionários recebem uma mensagem na ferramenta de colaboração corporativa de uma conta chamada IT Service Desk que usa o logotipo da empresa e um nome de exibição quase idêntico. A mensagem diz que o token MFA do funcionário deve ser recadastrado e direciona para [it-helpdesk-company.com](https://it-helpdesk-company.com). Vários usuários inserem credenciais antes que a segurança bloqueie o domínio. Qual ataque descreve melhor isso?

- A) Business email compromise
- B) Brand impersonation
- C) Watering hole
- D) Credential stuffing

### QUESTÃO 3 · CENÁRIO DE EXAME

Uma equipe de facilities descobre que lixeiras de reciclagem trancadas atrás de um escritório foram abertas à força durante a noite. Na semana seguinte, vários funcionários recebem ligações convincentes mencionando códigos internos de projetos, organogramas antigos e números de faturas de fornecedores. As informações mencionadas não estavam disponíveis online. Qual método de engenharia social provavelmente forneceu essas informações aos atacantes?

- A) Shoulder surfing
- B) Typosquatting
- C) Dumpster diving
- D) Hoax

#### QUESTÃO 4 · CENÁRIO DE EXAME

Uma diretora de vendas trabalha em uma proposta confidencial de fusão enquanto espera em um lounge de aeroporto. Uma pessoa sentada atrás se inclina repetidamente e parece observar a tela do notebook. Dias depois, um concorrente menciona detalhes da fusão em uma negociação. Nenhum malware ou comprometimento de e-mail é encontrado. Qual técnica provavelmente expôs a informação?

- A) Pretexting
- B) Dumpster diving
- C) Disinformation
- D) Shoulder surfing

#### QUESTÃO 5 · CENÁRIO DE EXAME

Um funcionário precisa enviar despesas pelo portal da empresa. Ele digita o nome do portal em um mecanismo de busca e clica em um link patrocinado para `company-expenses-portal.com` em vez de `companyexpenses.com`. O site parece idêntico e aceita suas credenciais corporativas. O funcionário é então redirecionado ao portal real. Qual técnica de ataque é essa?

- A) Typosquatting
- B) Pretexting
- C) Hoax
- D) Dumpster diving

#### QUESTÃO 6 · CENÁRIO DE EXAME

Durante uma fusão, um ator anônimo cria um memorando interno falso anunciando demissões imediatas e o publica em um fórum de discussão de funcionários. O memorando usa a assinatura do CEO e se espalha rapidamente, causando pânico. A segurança depois confirma que o memorando é falso e foi criado para manipular os funcionários. Qual termo descreve melhor essa atividade?

- A) Misinformation
- B) Disinformation
- C) Pretexting
- D) Impersonation

#### QUESTÃO 7 · CENÁRIO DE EXAME

Funcionários recebem um e-mail encaminhado alertando que um novo vírus apagará todos os arquivos se abrirem qualquer anexo PDF. O e-mail pede que os destinatários excluam arquivos compartilhados importantes e encaminhem o alerta para todos. A TI investiga e não encontra tal vírus nem anexo malicioso. Qual termo de engenharia social descreve melhor essa mensagem?

- A) Vishing
- B) Whaling
- C) Hoax
- D) Tailgating

#### QUESTÃO 8 · CENÁRIO DE EXAME

Um técnico de help desk recebe uma ligação de alguém que afirma ser o CFO. O chamador usa o nome do CFO, menciona uma recente reunião do conselho e exige uma redefinição imediata de senha da conta do CFO porque está bloqueado antes do prazo de um relatório financeiro. O técnico não consegue verificar a identidade do chamador por callback normal. Qual técnica de engenharia social está sendo usada?

- A) Typosquatting
- B) Dumpster diving
- C) Misinformation
- D) Impersonation

#### QUESTÃO 9 · CENÁRIO DE EXAME

Um funcionário bem-intencionado lê uma postagem não verificada em um fórum público alegando que o portal de benefícios da empresa foi invadido. Sem verificar com a TI, ele encaminha para dezenas de colegas, causando confusão. A alegação depois se revela falsa, mas o funcionário não tinha intenção de enganar. Qual termo descreve melhor a informação falsa espalhada?

- A) Misinformation
- B) Disinformation
- C) Pretexting
- D) Brand impersonation

#### QUESTÃO 10 · CENÁRIO DE EXAME

Após vários incidentes em que chamadores afirmavam ser auditores, equipe de suporte de TI ou executivos para obter informações, a equipe de segurança quer reduzir o sucesso dessas ligações. Qual controle é mais eficaz para esse problema específico?

- A) Implantar criptografia de disco completo em todos os endpoints
- B) Verificar identidade usando procedimentos de contato out-of-band pré-estabelecidos
- C) Aplicar privilégio mínimo para contas de serviço de banco de dados
- D) Configurar SPF, DKIM e DMARC

## GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

### **Questão 1: Alternativa A — Pretexting**

Pretexting está correto porque o chamador inventa um cenário e papel plausíveis — auditoria interna/revisão de conformidade — para manipular a funcionária a divulgar dados sensíveis. Typosquatting usa domínios semelhantes, dumpster diving envolve materiais descartados e shoulder surfing é observação visual direta.

### **Questão 2: Alternativa B — Brand impersonation**

Brand impersonation está correto porque o atacante se passa por um service desk interno confiável usando logotipo, nome de exibição e um domínio de suporte semelhante. BEC geralmente envolve comprometer ou falsificar uma conta de e-mail corporativa, watering hole compromete um site que as vítimas visitam, e credential stuffing usa credenciais vazadas anteriormente.

### **Questão 3: Alternativa C — Dumpster diving**

Dumpster diving está correto porque os atacantes provavelmente recuperaram documentos descartados contendo códigos internos de projetos, organogramas e números de faturas. Shoulder surfing é observação visual, typosquatting é abuso de registro de domínio, e um hoax é um falso alerta ou boato.

### **Questão 4: Alternativa D — Shoulder surfing**

Shoulder surfing está correto porque a informação provavelmente foi observada diretamente na tela em um local público. Pretexting usa um cenário inventado, dumpster diving usa materiais descartados, e disinformation é informação deliberadamente falsa espalhada para enganar.

### **Questão 5: Alternativa A — Typosquatting**

Typosquatting está correto porque o atacante registrou um domínio semelhante que se parece com o portal de despesas legítimo para capturar credenciais. Pretexting é um cenário inventado, um hoax é um falso alerta, e dumpster diving envolve recuperar informações descartadas.

### **Questão 6: Alternativa B — Disinformation**

Disinformation está correto porque a informação falsa foi deliberadamente criada e espalhada para manipular pessoas. Misinformation é informação falsa compartilhada sem intenção enganosa, pretexting é um cenário inventado para obter informações, e impersonation é fingir ser uma pessoa específica.

### **Questão 7: Alternativa C — Hoax**

Hoax está correto porque a mensagem é um falso alerta projetado para causar medo e levar os destinatários a tomar ações desnecessárias. Vishing é phishing por voz, whaling visa executivos seniores, e tailgating é entrada física não autorizada seguindo uma pessoa autorizada.

### **Questão 8: Alternativa D — Impersonation**

Impersonation está correto porque o chamador finge ser um executivo específico, o CFO, para obter uma redefinição de senha. Typosquatting abusa de domínios semelhantes, dumpster diving recupera dados descartados, e misinformation é informação falsa espalhada sem intenção enganosa.

### **Questão 9: Alternativa A — Misinformation**

Misinformation está correto porque a informação falsa foi compartilhada sem intenção de enganar. Disinformation é deliberadamente falsa e destinada a enganar, pretexting é um cenário inventado, e brand impersonation finge ser uma organização ou serviço confiável.

### **Questão 10: Alternativa B — Verificar identidade usando procedimentos de contato out-of-band pré-estabelecidos**

Verificar a identidade por meio de um procedimento de contato out-of-band pré-estabelecido está correto porque derrota tentativas de pretexting, impersonation e vishing que dependem da identidade alegada pelo chamador. Criptografia de disco completo, privilégio mínimo de banco de dados e controles de autenticação de e-mail não verificam um chamador ao vivo por telefone.

